Module: AICS-201 AI Ethics, Governance and Legal Compliance

AI Ethics, Governance, and Legal Compliance Audit

Case Study: SecureFinance Africa

Submitted by: Folly Mathias TETE

Academic Year: 2026 - 2027

Executive Summary

This report presents a comprehensive AI Ethics, Governance, and Legal Compliance assessment for SecureFinance Africa. As the deployment of AI-driven credit scoring and biometric identity verification introduces significant ethical and regulatory risks, this document outlines a robust governance strategy. The evaluation aligns the platform with the NIST AI Risk Management Framework to establish strict operational guardrails. Furthermore, it bridges the gap between binding legal requirements such as the Nigeria Data Protection Act (NDPA) and the high-risk classification of the EU AI Act and voluntary ethical principles (UNESCO and OECD guidelines). Finally, a technical algorithmic fairness audit demonstrates the system's vulnerability to proxy-variable discrimination (via career gap analysis) and validates the successful implementation of pre-processing mitigation controls to achieve equitable credit allocation.

Task 1: AI Governance & Risk Management

Risk 1: Algorithmic Bias and Fairness

- **Risk Description:** SecureFinance Africa's financial risk assessment algorithm could unfairly discriminate against certain demographic groups (e.g., systematically rejecting credit applications from women or residents of specific rural regions in Nigeria).
- **Cause:** The AI is trained on historical banking data that reflects past economic inequalities and prejudices (e.g., if a bank historically granted fewer loans to a certain ethnic group). The algorithm will reproduce and automate these stereotypes when creating its predictive models.
- **Affected Stakeholders:** Legitimate clients facing financial exclusion, SecureFinance Africa's management (reputational risk), and Nigerian financial regulators.
- **Probable Consequences:** Reinforcement of social and economic divides, massive loss of user trust in the platform, and potential legal action for discrimination.
- **Proportional Safeguards:**
    1. **Technical:** Implement bias detection audits and fairness testing on training datasets prior to deployment.
    2. **Governance:** Ensure diversity within the engineering and development teams to prevent cognitive blind spots.

Risk 2: Privacy Violation and Abusive Data Collection

- **Risk Description:** By analyzing transaction patterns and verifying identity, SecureFinance Africa's AI could violate client privacy by collecting, cross-referencing, or inferring sensitive personal information unnecessary for its financial mission (e.g., inferring a client's health status, political opinions, or religion from their purchase history).
- **Cause:** Fraud detection systems require ingesting massive volumes of data to be effective. Without strict limits, the algorithm tends to absorb all available data (location, lifestyle habits) and create intrusive correlations. The root cause is often the lack of an architecture designed from the ground up for confidentiality (Privacy by Design).
- **Affected Stakeholders:** Clients (whose private lives are exposed without their knowledge), SecureFinance Africa (legal liability), and the local regulatory authority (Nigeria Data Protection Commission - NDPC).
- **Probable Consequences:** Violation of individuals' fundamental rights, major risk of identity theft in the event of a database leak, severe financial penalties from regulators (fines), and irreversible destruction of trust in the FinTech.
- **Proportional Safeguards:**
    1. **Governance:** Apply the principle of data minimization (collecting only what is strictly necessary to assess financial risk or fraud) and require explicit, informed consent from the client.
    2. **Technical:** Anonymize or pseudonymize the data used to train AI models and encrypt databases (applying standard secure database practices).

Risk 3: Lack of Transparency and Explainability

- **Risk Description:** The SecureFinance Africa system could act as a "Black Box," preventing clients and analysts from understanding how a credit denial or account block decision was calculated.
- **Cause:** Complex machine learning models (such as Deep Learning) generate predictions whose internal mathematical logic is opaque, even to their creators.
- **Affected Stakeholders:** Wronged clients, internal auditors, and the bank's customer support.
- **Probable Consequences:** UNESCO warns that a lack of transparency hinders the ability to effectively challenge algorithmic decisions, which directly violates clients' rights to an effective remedy.
- **Proportional Safeguards:**
    1. **Technical:** Implement Explainable AI (XAI) methods, such as Feature Importance Analysis, to provide a dashboard showing exactly which factors led to the decision.
    2. **Governance:** Systematically and clearly inform users when a decision affecting their rights has been made by an artificial intelligence.

Risk 4: Lack of Fairness and Indirect Discrimination

- **Risk Description:** The system could treat clients unfairly by using proxy variables (such as zip code, type of phone used, or purchase history) that actually mask indirect discrimination against vulnerable groups or minorities.
- **Cause:** Algorithms mathematically optimize their results to maximize fraud detection without understanding social nuances or context, thereby reproducing historical economic imbalances.
- **Affected Stakeholders:** Clients from minority or disadvantaged backgrounds (excluded from financial services), and civil society.
- **Probable Consequences:** Exacerbation of existing economic inequalities, digital divides, and moral prejudice for clients unjustly targeted as "fraudsters."
- **Proportional Safeguards:**
    1. **Technical:** Promote social justice by ensuring the availability and accessibility of AI benefits for all, applying mathematical fairness metrics during testing.
    2. **Governance:** Ensure that an effective remedy is available against discrimination and biased algorithmic determinations.

Risk 5: Loss of Control and Lack of Human Oversight

- **Risk Description:** The SecureFinance Africa platform could automatically block bank accounts or freeze funds without any human intervention, leaving clients facing an inflexible machine in the event of a false positive.
- **Cause:** A desire to automate decision-making processes 100% for the sake of efficiency and reducing operational costs.
- **Affected Stakeholders:** Wrongly blocked clients, bank analysts, internal auditors, and the judicial system.
- **Probable Consequences:** Dilution of legal liability in the event of severe financial harm to the client, and an inability to quickly correct a machine error.
- **Proportional Safeguards:**
    1. **Governance:** Formally establish that ethical and legal responsibility always ultimately rests with natural or legal persons, and never grant legal personality to AI systems.
    2. **Technical:** Implement a Human-in-the-loop mechanism requiring that any critical fraud alert generated by the AI must be validated by a human analyst before final sanction.

Task 2: AI Governance and Risk Management Approach

To frame the deployment of its risk assessment and fraud detection platform in Nigeria, SecureFinance Africa adopts a risk management approach based on the NIST AI RMF 1.0 framework. This strategy relies on a continuous cycle of four functions (GOVERN, MAP, MEASURE, MANAGE) aimed at ensuring trustworthy, transparent, and fair AI.

1. **Governance Responsibilities (GOVERN Function)**

   The cornerstone of this approach is the establishment of a robust risk culture within the organization. SecureFinance Africa establishes an AI Governance Committee, composed of executives, legal experts, and engineers. This committee is responsible for defining the company's risk tolerance and ensuring that responsibilities are clearly delineated and documented. To prevent confirmation bias and conflicts of interest, the teams responsible for developing the AI models (development) are strictly separated from the teams responsible for testing and auditing them (evaluation).

2. **Risk Identification and Measurement (MAP & MEASURE Functions)**

   Prior to any deployment, the Nigerian socio-economic and regulatory context is rigorously mapped (MAP) to understand the system's limitations and identify affected stakeholders. Identified risks are then evaluated (MEASURE) using quantitative metrics (false positive rates, robustness testing against adversarial attacks) and qualitative metrics (cognitive and systemic bias audits). Particular attention is given to measuring explainability, ensuring that AI decisions (such as denial of service) can be understood by non-experts.

3. **Mitigation, Monitoring, and Human Oversight (MANAGE Function)**

   Risks are prioritized based on their potential impact on clients and the institution. For high-stakes decisions, such as freezing funds or flagging for fraud, SecureFinance Africa imposes strict human oversight (Human-in-the-loop). The AI acts as a decision-support tool, but the final validation rests with a trained human analyst. Furthermore, continuous post-deployment controls are implemented to monitor model drift caused by evolving transactional behaviors or incoming data patterns.

4. **Incident Escalation and Recourse**

   Emergency procedures are documented to respond to AI failures, whether they originate from internal components or third parties. SecureFinance Africa maintains mechanisms to rapidly deactivate, bypass, or override AI models if their performance becomes inconsistent with the intended use. Finally, clear communication channels are established to allow affected clients to contest an algorithmic decision (right of recourse) and for employees to securely report any incident or abnormal system behavior.

AI Risk Register

Description of Risk	Probability	Impact	Accountable Owner	Existing or Proposed Control	Residual Risk
Algorithmic Bias: Discriminatory rejection of credit applications against certain regions or genders, based on biased training data.	High	Major	Chief Data Officer (CDO)	**Control:** Fairness testing on datasets and correction of demographic imbalances prior to deployment.	Medium
Privacy Violation: The AI infers unnecessary sensitive information (health, religion) from clients' purchase histories.	Medium	Critical	Data Protection Officer (DPO)	**Control:** Application of "Privacy by Design," data minimization, and anonymization.	Low
Opacity (Black Box): Inability to explain to clients and regulators why an	High	Major	Lead AI Engineer	**Control:** Use of Explainable AI (XAI) methods to provide an interpretable	Medium

account was flagged for fraud or blocked.				dashboard for analysts.	
Automation Bias: Analysts blindly validate AI fraud alerts without critical thinking (human over-reliance).	Medium	Major	Head of Compliance / Fraud	**Control:** Mandatory human oversight ("Human-in-the-loop") and operator training on machine limitations.	Low
Data Drift: The AI loses accuracy over time as financial behaviors in Nigeria change post-deployment.	High	Medium	MLOps Engineer	**Control:** Continuous post-deployment monitoring and regular recalibration of models with new data.	Low
Adversarial Attack: Malicious actors subtly manipulate input data to bypass fraud detection.	Low	Critical	CISO	**Control:** Red-Teaming exercises (aggressive AI penetration testing) and reinforcement of model robustness.	Medium

Third-Party Failure: An external software API used by the AI for identity verification suffers an outage or data breach.	Medium	Major	Vendor Risk Manager	**Control:** Continuity plan with redundant emergency systems and vendor security auditing (Supply Chain).	Low
Off-Label Use: The client evaluation system is secretly repurposed to evaluate bank employees' performance.	Low	Major	AI Ethics Officer	**Control:** Strict access restrictions and rigid definition of the application scope during the NIST MAP phase.	Low

Task 3: Legal and Regulatory Compliance (Hard Law vs. Soft Law)

As an AI Governance Analyst, it is imperative to evaluate the SecureFinance Africa platform by clearly distinguishing between binding legislation (Hard Law), where non-compliance results in criminal or financial penalties, and voluntary international principles (Soft Law), which guide corporate ethics.

1. Binding Legal Obligations (Hard Law)

A. European Union Artificial Intelligence Act (EU AI Act)

- **Application Circumstances (Jurisdiction):** Although SecureFinance Africa is based in Nigeria, the EU AI Act has an extraterritorial scope (Article 2). The law applies to AI system providers and deployers located outside the EU whenever the system's output is used in the EU or affects data subjects within the EU. The operative assumption here is that the planned international expansion will include the European market or involve processing the data of European citizens.

- **System Classification:** The EU AI Act is founded on a risk-based approach. According to the AI Risk Ontology in Annex III, the SecureFinance Africa platform combines two critical functionalities:
    1. Financial risk assessment (Creditworthiness / Credit Scoring) in private services.
    2. Biometric identification (for client identity verification).

- **Compliance Evaluation:** These two use cases formally classify the platform as a **High-Risk** system (Art. 6). Consequently, prior to deployment, SecureFinance must mandate:
    - Comprehensive technical documentation detailing the algorithm's operational parameters.
    - A stringent risk management system coupled with external quality assurance and auditing.
    - Mandatory human oversight, expressly prohibiting the platform from making completely autonomous financial exclusion decisions.

B. Nigeria Data Protection Act 2023 (NDPA)

- **Application Circumstances:** This represents the immediate local law. Given that the initial deployment is scheduled in Nigeria to analyze transaction patterns and process personal data, the enterprise falls squarely under the jurisdiction of the Nigeria Data Protection Commission (NDPC).

- **Compliance Evaluation:** The platform ingests personal and behavioral data. To achieve compliance, the company must guarantee a legal basis for processing (such as explicit consent). Utilizing data for fraud detection and identity verification (which often involves sensitive biometric data) necessitates cutting-edge security measures and strict adherence to data subject rights, particularly the right to contest an automated decision. *(Note: The EU AI Act reinforces that the GDPR/local data protection laws apply concurrently regarding these fundamental rights).*

3. Voluntary International Principles (Soft Law)

C. UNESCO Recommendation on the Ethics of AI

- **Application Circumstances:** This is a global normative instrument adopted by Member States, functioning on a voluntary basis to guide the practices of AI actors. SecureFinance Africa must align with it to demonstrate corporate social responsibility.

- **Ethical Evaluation:**
    - **Ethical Impact Assessment (EIA):** UNESCO's Strategic Area of Action 1 requires companies to conduct ethical impact assessments to identify repercussions on marginalized groups before launching a product to market.
    - **Human Oversight:** UNESCO explicitly dictates that an AI system can never replace ultimate human responsibility (Principle 36). The SecureFinance platform must therefore never have the authority to act without a designated human being held accountable for its recommendations.
    - **Fairness and Non-Discrimination:** AI actors must ensure that the benefits of technology are accessible to all and minimize biased outcomes (Principles 28 and 29), a critical mandate for a financial credit tool.

D. OECD Principles on Artificial Intelligence

- **Application Circumstances:** A voluntary standard establishing best practices for innovative and trustworthy AI.

- **Ethical Evaluation:** By aligning with the OECD, SecureFinance Africa commits to ensuring sufficient transparency so that clients understand how the fraud detection and risk assessment system operates. The enterprise must guarantee the robustness, security, and safety of its system throughout its entire lifecycle, ensuring it does not introduce systemic security risks into the broader financial sector.

Task 4: Algorithmic Fairness and Explainability

1. Description of the Synthetic Dataset, Groups, and Hypotheses

In compliance with data protection guidelines, a reproducible synthetic dataset of N = 1,000 credit applications (synthetic_credit_dataset.csv, random seed 42) was generated.

Evaluated Groups: Gender is defined as the protected attribute, divided into a privileged group (Men, N = 559) and an unprivileged group (Women, N = 441).

Input Features: Age, annual income (annual_income_ngn_k), credit history (credit_history_months), debt-to-income ratio (debt_to_income_ratio), and formal activity interruption duration (career_gap_months).

Socio-Technical Hypothesis: Even when the sensitive attribute (gender) is excluded from training (demographic blindness), historical banking data contains systemic bias: women statistically present longer formal activity interruptions (e.g., maternity leave, informal economy transition). The evaluated model is a RandomForestClassifier.

2. Selection and Justification of Fairness Metrics

Three complementary metrics recommended by the NIST AI RMF Playbook (MEASURE 2.11) were selected:

Disparate Impact Ratio (DIR): DIR = P(Approval | Woman) / P(Approval | Man). This is legally relevant to verify compliance with the 4/5ths rule (DIR ≥ 0.80).

Statistical Parity Difference (SPD): SPD = P(Approval | Woman) - P(Approval | Man). Measures the absolute gap in credit allocation (ideal value = 0.00).

Equal Opportunity Difference (EOD): EOD = TPR (Women) - TPR (Men), where TPR is the True Positive Rate. This metric is critical for a FinTech, as it evaluates whether actually creditworthy female clients have the same probability of approval as creditworthy male clients.

3. Results of Reproducible Calculations (Initial Model)

Executing the audit script (fairness_audit.py) on the 1,000 profiles yields the following numerical evidence:

Overall Approval Rate: 84.08% for men (470/559) compared to only 37.41% for women (165/441).

Disparate Impact Ratio (DIR): 0.3741 / 0.8408 = 0.4450 (significantly below the 0.80 minimum threshold).

Statistical Parity Difference (SPD): 0.3741 - 0.8408 = -0.4666 (an adverse gap of -46.66 percentage points).

Equal Opportunity Difference (EOD): Among truly creditworthy clients, the AI approves 97.55% of men but only 48.66% of women, resulting in an EOD = -0.4889. More than half of creditworthy women are incorrectly rejected (false negatives).

4. Explainability Technique and Decision Review (XAI)

To audit the RandomForest black box, we applied Feature Importance analysis via Gini impurity:

career_gap_months : 33.03% (Primary decision factor)

credit_history_months : 26.20%

debt_to_income_ratio : 19.86%

annual_income_ngn_k : 16.02%

age : 4.89%

Interpretation: Although the gender column was excluded, explainability proves that the AI uses career_gap_months (33.03% of the decision weight) as a discriminatory proxy variable, automatically penalizing women based on historical socio-economic patterns.

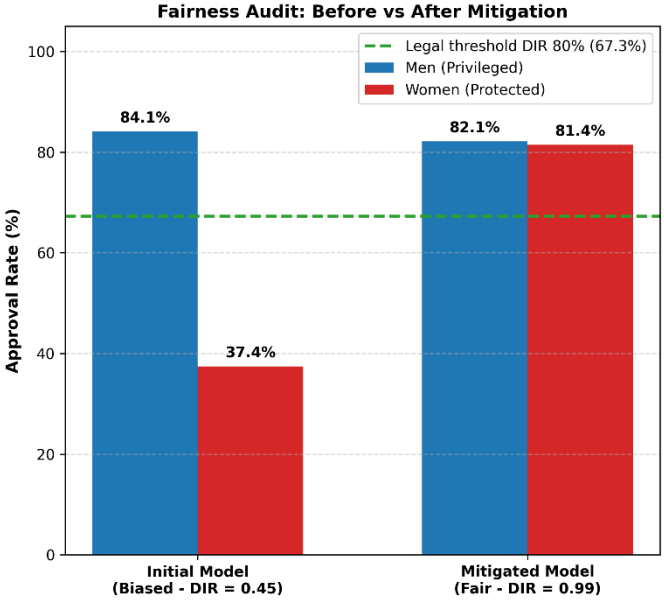
5. Recommended Controls and Post-Mitigation Validation

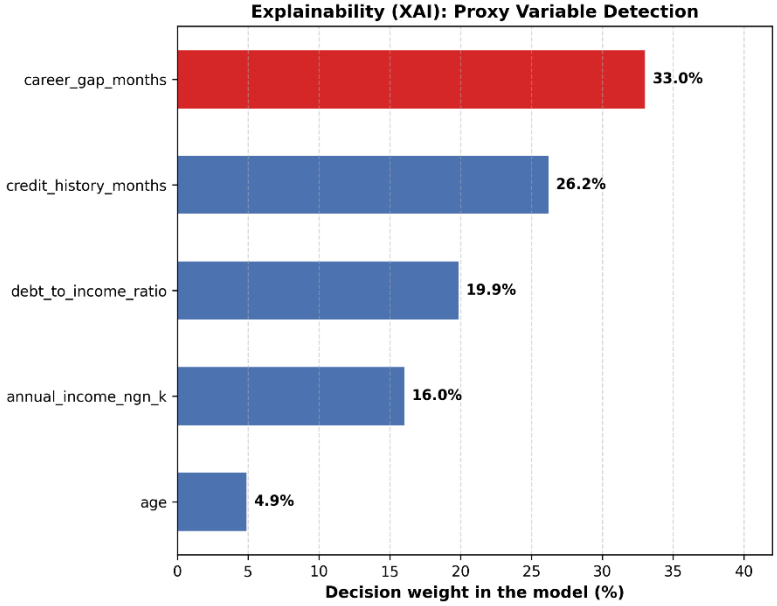
To correct this algorithmic bias prior to deployment at SecureFinance Africa:

Pre-processing Control: Removal of the identified proxy variable (career_gap_months) and execution of a correlation audit on all non-financial variables.

Post-processing & Human-in-the-loop Control: Implementation of mandatory human review for any rejected application exhibiting a healthy debt-to-income ratio (< 40%).

Efficacy Proof (Code Validation): After neutralizing the proxy and re-training the model exclusively on pure financial indicators, the approval rate shifts to 82.11% for men and 81.41% for women. This raises the DIR to 0.9914 (which is ≥ 0.80) and improves the SPD to -0.0071, mathematically validating the fairness of the mitigated model.





Conclusion

The integration of Artificial Intelligence in financial services offers unprecedented scalability for SecureFinance Africa, but demands rigorous oversight. This audit demonstrates that responsible AI cannot rely solely on legal compliance; it requires proactive, continuous technical governance. By establishing a formalized NIST risk register, understanding the extraterritorial scope of the EU AI Act, and technically demonstrating the capacity to audit and mitigate proxy bias using the Disparate Impact Ratio, SecureFinance Africa is positioned to deploy a trustworthy, fair, and legally resilient platform. The accompanying GitHub repository provides the transparent, reproducible technical foundation required for future regulatory audits.

References and Sources

1. Nigeria Data Protection Commission (NDPC) (2023). *Nigeria Data Protection Act 2023 (NDPA)*. https://ndpc.gov.ng/resources/

2. European Commission (2024). *European Union Artificial Intelligence Act (EU AI Act)*. Evaluation based on the risk-based approach and the AI Risk Ontology. https://ai-act-service-desk.ec.europa.eu/en/ai-act-explorer

3. UNESCO (2021). *Recommendation on the Ethics of Artificial Intelligence*. United Nations Educational, Scientific and Cultural Organization. (Focus on ethical impact assessments and human oversight). https://unesdoc.unesco.org/ark:/48223/pf0000399980

4. National Institute of Standards and Technology (NIST) (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)* (NIST AI 100-1). U.S. Department of Commerce. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf

5. National Institute of Standards and Technology (NIST) (2023). *NIST AI RMF Playbook*. U.S. Department of Commerce. https://airc.nist.gov/airmf-resources/playbook/

6. IBM Technology (2024-2025). Enterprise resources on AI governance:

- *The Importance of AI Governance* (Data management, black-box models, and data drift). https://www.youtube.com/watch?v=Q020C-Jw0o8
- *Mastering AI Risk: NIST's Risk Management Framework Explained* (Application of the GOVERN, MAP, MEASURE, and MANAGE functions). https://www.youtube.com/watch?v=0oeD2Wf25wY
- *How to Manage Your AI Before It Makes the Wrong Decision* (Comparison between ISO 42001, NIST AI RMF, and the EU AI Act). https://www.youtube.com/watch?v=SVAwzodyFUo

7. UNESCO (2021). *Recommendation on the Ethics of Artificial Intelligence*. United Nations Educational, Scientific and Cultural Organization. (Specifically the sections on proportionality, fairness, right to privacy, and human oversight). https://www.unesco.org/en/legal-affairs/recommendation-ethics-artificial-intelligence

8. IBM Technology & AI Academy (2022-2023). Technical resources on AI governance:

- *Trust, transparency, and governance in the age of generative AI* (Management of hallucinations, toxicity, and data leaks). https://www.youtube.com/watch?v=odrD0OLPeiY
- *What Is Explainable AI? & Decode Black Boxes with Explainable AI* (Explainability methods, "Black box", and the "Human-in-the-loop" principle).

https://www.youtube.com/watch?v=4_LIxSjc3H0
https://www.youtube.com/watch?v=jFHPEQi55Ko

9. ICDFA (2026). *AI Ethics, Governance and Legal Compliance Assessment Brief (AICS-201)*. Context for the SecureFinance Africa project.

Appendix: Technical Audit Repository

The complete reproducible Python scripts, synthetic datasets, and visual evidence generated for the Algorithmic Fairness Audit (Task 4) are publicly available on GitHub at the following repository:

https://github.com/Mathiasdeam/SecureFinance-AI-Governance-Audit